CDA in Brief

Talking points and conversation pieces from
IMS for Communications Data Acquisition

Prepared for Michael Rossi
October 2026 — companion to the full course

Contents

Contents 2
1. The thirty-second version 4
2. The five tensions 5
3. Law to requirement 6
4. The taxonomy — entity, events, content 7
5. What IMS gives you 8
6. Identity and time 9
7. The honest limits 10
8. Architecture positions 11
9. Retention 12
10. The seam — interface and handover 13
11. Security and insider risk 14
12. Assurance and evidential weight 15
13. Running the programme 16
14. One-liners 17

How to use this

This is the course compressed into things you can say. Each section opens with a one-line position, follows with the argument behind it, and closes with a question you can ask in a design review or a stakeholder meeting. It is written to be read on a phone before a meeting, not studied. Where a statement rests on law, the caveat from the full course stands: written as at September 2026, check the current Act and Code before it becomes a design constraint.

Section	Use it when
1. The thirty-second version	Someone asks what CDA actually is
2. The five tensions	A design review is going round in circles
3. Law to requirement	Somebody says 'shall comply with the Act'
4. The taxonomy	A field classification is being waved through
5. What IMS gives you	A vendor or an authority over-claims
6. Identity and time	A resolution design is being presented
7. The honest limits	A business case assumes constant yield
8. Architecture positions	Reviewing a solution or vendor architecture
9. Retention	Capacity, deletion or backups come up
10. The seam	Interface specifications are on the table
11. Security	Insider risk or compartmentation is discussed
12. Assurance	Evidence, errors, inspections
13. Running the programme	Setting up or rescuing the design authority
14. One-liners	You need a sentence, fast

1. The thirty-second version

> *Communications data acquisition is the lawful obtaining, by a public authority from an operator, of data about a communication — who, when, where, how, with whom — but never what was said.*

Every word carries a design consequence. **Lawful** means an authorisation regime and an audit obligation. **From an operator** means an interface between two organisations with different incentives. **About a communication** means a taxonomy with a legally sharp boundary. **Never what was said** means a filter that must be demonstrably effective.

The UK frame is the Investigatory Powers Act 2016, amended in 2024. Three parts matter: Part 3 lets an authority *acquire*; Part 4 compels an operator to *retain*; Part 9 is where a notice turns a legal duty into an engineering requirement with a date. Parts 3 and 4 are a pair — one makes the data exist, the other obtains it — and almost all the interesting design work lives in the seam between them.

The side being governed here is the operator's: the disclosure capability and the interface to the acquiring authority. The operator's duty is to disclose what it holds, accurately, when lawfully required. It is not to investigate, interpret or help build a case.

QUESTION TO ASK

Which part of the Act is generating the requirement in front of us — acquisition, retention, or a notice? Show me the clause.

2. The five tensions

Most design disagreements are not about technology. They are about which of five tensions is being prioritised. Naming the tension usually ends the argument.

Tension	The pull each way	Where the design decides it
Completeness vs minimisation	Authority wants everything relevant; law requires no more than necessary; operator wants to hold as little as possible	What is retained, at what granularity, for how long, and what a query may return
Latency vs deliberation	Threat-to-life needs minutes; a court case in three years needs provenance	Whether there are two pipelines or one pretending to be both
Automation vs judgement	Machines are faster and more auditable; regulators expect a person to have judged scope, content and third-party data	Where the human sits — a governance decision disguised as workflow
Evidence vs speed	Evidential standard is unaffordable for everything; none of it is negligent	Which disclosures are built to evidential standard
Capability vs exposure	Every field, query and interface is also an attack surface and a political liability	What is deliberately not built

The clean position: machine determines scope from the authorisation; a human approves release. That division scales and survives inspection.

> **QUESTION TO ASK**
>
> Which of the five tensions are we actually arguing about? And have we recorded which way we chose to resolve it?

3. Law to requirement

A notice is a legal instrument, not a requirements document. Somebody has to translate it, and the translation is a governed, versioned artefact.

```
Legal instrument -> Interpretation -> Capability statement -> Requirement
(notice, s.xx,     (legal opinion,     (what we must be         (testable,
 Code of Practice)  recorded, dated)    able to do)              traceable)

every link versioned; a change anywhere re-validates everything downstream
```

Two disciplines. Never let a requirement cite the law directly — 'shall comply with section 87' is untestable; it must cite an interpretation. And record the negative decisions: what was deliberately not built is the evidence of minimisation, and the first thing an inspector asks when a capability looks narrower than the notice.

The requirements the law generates — short form

Legal concept	Requirement	Evidence
Necessity and proportionality	Return no more than the authorisation permits	Scope enforced at query time; requested vs authorised vs returned logged
Entity vs events	Every field classified; classification drives access	Catalogue as a build artefact; sign-off record
Serious crime threshold	Authorisation type checked before events data is released	Machine-readable authorisation attributes
ICRs (s.62)	Separate capability, separate control, separate audit	Distinct approval and audit stream
Content exclusion	No content, including content inferable from over-granular data	Per-field boundary analysis; truncation; review point
Retention limits	Automated, verifiable deletion	Deletion evidence retained longer than the data
'Without undue delay'	Defined response times and an urgent path	SLA instrumentation
s.11 lawful authority	Refuse requests lacking valid authority	Refusal is a designed, logged outcome
Oversight	Every disclosure reconstructable years later	Immutable audit outliving the data
Notification notices (s.258A)	Detect notifiable change in your own release process	Capability-impact question on every change

> **QUESTION TO ASK**
> Where is the interpretation record between this clause and this requirement, and when was it last reviewed?

4. The taxonomy — entity, events, content

Three categories. The first two carry different legal thresholds — events data for the crime purpose needs the serious-crime threshold, entity data does not — so classification has legal effect, not just data-modelling effect.

Category	Answers	Examples
Entity	Who or what	Subscriber behind a number; IMSI/IMEI on an account; services provisioned; IMPI/IMPU bindings
Events	What happened, when	Call start/end/parties; registration at a cell; message sent; data session start/stop
Content	What was communicated	Message body; audio; a full URL beyond the host; free text in a signalling field

The hard cases are three: **granularity** (example.com identifies a service; example.com/support/bereavement reveals substance), **signalling that carries meaning** (a subject line in a header is content in a metadata-shaped place), and **inference from aggregation** (one record is events data; a long enough sequence is pattern of life).

Four controls make the taxonomy real rather than asserted: a machine-readable catalogue the pipeline consumes; classification-driven scope enforcement at the gateway; truncation at the point of generation, irreversibly; and a human review point with a defined rule for when it is required.

The third-party rule: do not enrich by default. Resolving the other party's number to a name is a fresh disclosure about a person who is not the subject of any authorisation. When the tooling does it automatically, the error is designed in.

> **QUESTION TO ASK**
> Which classifications are arguable, who signed them off, and where is the rationale? A table with no 'depends' entries is concealing decisions, not making them.

5. What IMS gives you

IMS is the operator's service core for voice, video and messaging over packet networks. Three facts are enough to reason about the data it produces.

1. **Signalling and media travel separately.** Control passes through the core; voice does not. Communications data and content are physically separable — the architecture and the law agree.
2. **The home network always sees the transaction.** However far the user roams, the session passes the home serving node, so CSP-side retention is viable.
3. **IMS is access-independent.** One core serves 4G, 5G, Wi-Fi calling and fixed. It tells you identity and event; location must be correlated in from the access network.

Node	What it knows	Why you care
S-CSCF	Both identities, session start/end, service invoked, outcome	The authoritative session record — retain this if nothing else
P-CSCF	Access type, UE IP:port, cell identity, registration	The location and access story
TAS	Diversion, barring, transfer, conference	The 'why' behind an odd record — usually under-retained
HSS	IMPI, IMPUs, MSISDN, IMSI, service profile	The entity-data backbone
IBCF	Peer operator and inter-operator identifiers	Where the authority sends the next enquiry
Charging	The consolidated record	The tempting but dangerous shortcut

One call produces several records in several systems. Correlation, not capture, is the hard part — and the charging identifier (ICID) is the practical correlation key. Never join on time-and-identifier heuristics; a 99% join produces undetectable wrong disclosures about real people in the other 1%.

What IMS does not tell you

- Continuous location — only cell granularity at the moments signalling happens.
- Anything about over-the-top apps — an encrypted session to a cloud provider.
- Who was holding the device — an identity used a service; that is all.
- Whether a call was answered by a person, or what was said.

On charging records: reusing them is a legitimate first release and a dangerous end state. They omit unanswered calls and zero-rated events, change whenever the tariff changes, and tie a regulated capability to a commercial roadmap. Insist on a field-by-field gap analysis against the notice and a change-coupling statement naming who is consulted before a billing change goes live.

> **QUESTION TO ASK**
> Which node is the system of record for each event type, and what happens when two disagree?

6. Identity and time

Every identifier lookup is only valid with respect to a time. Bindings are intervals, not facts.

A person is not an identifier: one person holds several MSISDNs, several IMPUs, a tablet with its own IMPI. And identifiers are reused: numbers are recycled, IP addresses reassigned by the second, IMEIs cloned. A resolution that returns a single value for a period spanning a reassignment produces a confident answer about the wrong person.

```
Request: MSISDN=X, Feb 2026
  01-14 Feb : account A
  15-19 Feb : NOT ALLOCATED   <- say so explicitly
  20-28 Feb : account B       <- a different person
```

Three resolution problems: identifier to subscriber (entity); identifier to other identifiers (entity, but each hop may be a disclosure about a different person — bound it, configure it per authorisation, audit the hop count); identifier plus time to events (the higher threshold, and only after the first two are right).

Carrier-grade NAT is where it most often fails. Hundreds of subscribers share one public address, so resolution needs the source port and an accurate time — a clock skew of seconds turns a right answer wrong. Consequences: port is mandatory in the interface, time synchronisation is a correctness control with assurance evidence, and NAT logs are the dominant capacity driver. Deterministic NAT allocation cuts that volume by orders of magnitude and is usually decided by the IP team without reference to the programme.

Also: distinguish 'not our subscriber' from 'no activity' — an empty result is indistinguishable from a quiet period. Keep resolution and retrieval as separate, separately authorised services, or the entity/events boundary cannot be demonstrated.

> **QUESTION TO ASK**
> Does resolution return time-segmented results with explicit gaps? How many hops can it perform, and is the bound in the audit record?

7. The honest limits

The commonest failure in CDA programmes is not technical. It is a requirement accepted that the data could never satisfy. Four limits belong in a written capability statement that the authority acknowledges.

1. The data describes the service, not the person. Identity to person is an inference, and the disclosure should not present it as more.
2. Absence of a record is weak evidence of absence of an event. Feeds fail silently, nodes restart, record types were never retained. 'We hold no record' and 'nothing happened' are different statements.
3. Timestamps are approximate and heterogeneous. State accuracy, not precision.
4. Location is coarse, occasional and inferred. A sequence of cell sightings is not a track.

The erosion problem: the share of a person's communications visible to a network operator is falling — OTT apps, encrypted DNS and SNI, CGNAT and VPNs, flat-rate tariffs that removed the commercial reason to generate records. A business case that assumes constant evidential yield is wrong. The right posture is modularity: sources will change; do not couple schema, query model and interface so tightly that replacing a source means rebuilding the system.

What holds its value: identity resolution (only the operator can do it, resilient to encryption), registration and attachment events, service-layer records where the operator is the service, and corroboration by pattern.

Three cheap artefacts prevent most expectation failures: a data availability matrix per request type; a defined nil-return vocabulary (not our subscriber / not allocated in period / no records held / insufficient information / outside scope); and a caveat that travels with the data.

> **QUESTION TO ASK**
> Is there a requirement here about continuous location or OTT services? Has the capability statement been published and acknowledged?

8. Architecture positions

Six layers, five boundaries, and each boundary carries a named control. Collapsing a boundary removes a control.

```
L6  External interface      authenticated, structured, audited
L5  Disclosure management   validate authority, resolve scope, review, release
L4  Query and resolution    entity resolution | events retrieval (separate)
L3  Retention store         immutable, classified, time-partitioned, expiring
L2  Ingest / normalisation  parse, TRUNCATE, classify, correlate, reject
L1  Sources                 IMS nodes, access, NAT, HSS, business systems
L0  Cross-cutting           audit, time, IAM, keys, monitoring, change
```

Boundary	Control applied there
L1 to L2	Content truncation and parsing — the irreversible one
L2 to L3	Classification and quality gating; nothing unclassified is stored
L3 to L4	Retention enforcement; expired data is not queryable
L4 to L5	Scope enforcement: authorisation intersected with request
L5 to L6	Human review, caveat attachment, release authorisation

The three non-recoverable decisions

Decision	Position to argue for
Where is content-bearing granularity removed?	At ingest, before storage, irreversibly. At generation if the elements allow it. Never at disclosure.
Is retention a copy or the system of record?	A dedicated store for anything under a notice. Hybrid is defensible only with an explicit boundary between compelled and other-basis data.
How is scope enforced?	In a scope-resolution service beneath the application, producing the requested/authorised/returned triple. 'We trained our staff' is a materially weaker answer than 'the system could not have'.

When a vendor presents an 'investigation workbench' that merges query and disclosure management, the question is not whether it is wrong but where scope is enforced — by the application the user is driving, or by a service beneath them — and how that changes the audit story.

> **QUESTION TO ASK**
>
> Map the product onto the six layers. Where does each control live? Where does scope enforcement happen — and can a user with data-layer access bypass it?

9. Retention

The notice is the schema's requirements baseline: retain what it specifies and nothing more. Up to twelve months; same standard as business data; disclosure without undue delay; destruction at the end of the period — including from backups.

Three data families, physically separate: an interval-keyed entity/binding store (low volume, high value), a time-partitioned append-only events store (high volume), and resolution aids such as NAT translations (huge volume, short life). Different volumes by orders of magnitude, different retention arguments, and the entity/events access boundary becomes physical.

Time partitioning is the deletion mechanism, not an optimisation. Deletion must produce evidence that outlives the data. Legal hold is a designed feature, not a suspended job. And crypto-shredding — per-partition keys destroyed at expiry — is usually the only workable answer to the backup problem.

Challenging a capacity plan

- What is the ratio of NAT translation records to session records, and was it measured or assumed?
- Does the model include indexes, replicas and the correlated copy?
- What is the steady state at twelve months, not the growth curve?
- What happens if an IoT or fixed-wireless population is added mid-life?
- Can records be re-derived if a classification decision changes?

The one operational control to take from the whole course: **volume reconciliation against source-side counts**. A feed that stops produces no errors — it produces silence, and silence looks like a quiet period. Every disclosure in that window is potentially incomplete and nobody knows.

> **QUESTION TO ASK**
>
> Does backup retention exceed data retention? If so, what prevents expired data being restored? And what was yesterday's expected versus actual volume per feed?

10. The seam — interface and handover

The interface is the only part neither party wholly controls, so it is where the residual risk lives. Two principles: the authorisation must arrive machine-readable (type, purpose, data classes, period, expiry) or scope enforcement can only ever be procedural; and the interface must express partial and negative outcomes richly.

Standard	Role
ETSI TS 103 120	Request and authorisation exchange — the modern replacement for email and portals
ETSI TS 102 657	Retained-data request/delivery (HI-A/HI-B) and the record schemas
ETSI TS 102 232	Delivery transport
3GPP TS 33.126/127/128	Network-side LI architecture: ADMF, POIs, MDF2, LI_X and LI_HI interfaces

The uncomfortable fact for a design paper: the 3GPP architecture carries both content and communications data. Separation is achieved by authorisation and provisioning, not physics — so the controls that keep them apart are administrative and must be exceptionally well evidenced. If the capability is CD-only, demonstrate that the content path is not provisioned; do not assert it.

Ambiguity belongs with the authority, not the operator. The CSP returning its 'best interpretation' is making a judgement it has no authority to make. That requires a first-class clarification message — not email. A usable message catalogue has at least: submit, acknowledge, clarify, amend, withdraw, status, deliver, error, nil-return.

Urgent path: narrow it to a pre-agreed set (identity resolution, recent location), move the human to after release rather than removing them, review every urgent disclosure, make it visibly different in the audit, and rehearse it out of hours.

Strongest control at the seam: reconcilable audit at both ends, with signed requests and responses, so that years later both parties can prove what was asked and what was sent — and a compromised endpoint sending plausible, well-formed, unauthorised requests is detectable.

> **QUESTION TO ASK**
> Show me the message catalogue. Is there a clarification message? Do both parties keep reconcilable audit, and does anyone actually reconcile it?

11. Security and insider risk

> *The defining property of this threat model: misuse looks exactly like use. A query run for a personal reason is technically identical to one run for an investigation.*

That forces detection alongside prevention. Compartmentation: provisioning, data, disclosure and audit are separately staffed and separately administered. Platform engineers cannot run disclosure queries; disclosure officers cannot change the system; nobody administers their own audit; privileged actions need two people.

Access control must take the authorisation as an input and decide per request, not per session. A user with a valid role and no live authorisation can do nothing. Accreditation is a checked attribute, not an HR record, so a lapse removes capability automatically.

Keys are the control: per-partition keys serve deletion, compartmentation and the proof that platform staff could not read what they administered. If one team holds all the keys, compartmentation is nominal.

Cheapest high-yield detection: self-query and associate-query alerting. Historically it is the pattern most real insider incidents in comparable systems have followed. Then query-to-authorisation reconciliation, per-user volume anomalies, subject-of-interest alerting, and routine reconciliation with the authority's own records.

Vendors: standing remote access into a CDA estate is very hard to defend; supervised, time-bounded, recorded break-glass access is the alternative. Closed components in the resolution path rest the assurance case on vendor assertions. And data portability is a compliance issue, not a commercial one — if you cannot migrate the retained data, you cannot meet the notice with a different supplier.

> **QUESTION TO ASK**
> Can platform engineers run disclosure queries? Prove it. Who holds the keys? Do we detect self-queries?

12. Assurance and evidential weight

Three standards, often confused: data quality (accurate, complete, timely), data integrity (provably unchanged), and evidential weight (will a court rely on it). Decide explicitly which disclosures are built to evidential standard. In most operators the honest answer is all of them — reach that deliberately, with its cost accepted.

Evidential weight needs provenance, integrity, repeatability, explicability and continuity. **Explicability is an architectural veto**: probabilistic matching, opaque enrichment and adaptive heuristics produce answers nobody can explain in a witness box. The question to a vendor is not 'how accurate is it?' but 'who will explain it, and what happens when they cannot?'

Quality: measure against independent expectation, never against the feed's own count; report the tail, not the mean. A completeness statement that travels with every disclosure — which feeds were down, how many records correlated, what location was absent — is cheap to generate from the controls already in place and more useful than a hundred extra records.

Errors: a taxonomy (wrong subject, excess disclosure, content disclosure, third-party over-disclosure, incomplete, late, unauthorised query, retention failure), each with detection, notification and — the step routinely missing — a way to enumerate the past disclosures affected. Detecting an error you cannot trace is not remediation.

The single most useful demand a design authority can make: produce the assurance evidence pack for one month, before go-live, on test data. What cannot be produced is a gap in the design.

> **QUESTION TO ASK**
> Produce the assurance pack for one month. For a sampled disclosure, show me the requested, authorised and returned field sets. For each error class, can we enumerate affected disclosures?

13. Running the programme

Five things make governing this different: the requirements baseline is a legal instrument; the customer is not the user; failure is asymmetric (over-delivery is also a breach, and a worse one in privacy terms); the evidence is part of the deliverable; and the lifetime outlasts the network generation that fed it.

A design authority that reviews documents rather than taking decisions from a list is a reading group. The test: can a decision taken there be produced, with rationale and date, two years later? The standing decision list includes classification of arguable fields, truncation point, copy-vs-system-of-record, scope mechanism, correlation key, identifier hop bound, urgent path scope, human review rule, nil-return vocabulary, source system-of-record nominations, vendor access model and notifiable-change criteria.

Buy the plumbing, own the policy. Storage, ingestion, indexing, transport and workflow are commodity. Classification, scope enforcement, correlation rules, the nil-return vocabulary, the caveat model and the audit schema are your compliance posture, expressed in configuration you control and portable between suppliers.

Change: a mandatory capability-impact question on every change record — *does this alter what communications data we generate, retain, can resolve or can disclose, in kind, granularity, timeliness or completeness?* — is the operational mechanism behind both the notification-notice obligation and regression control.

First hundred days

1. Get the instruments — notices, current Code, interpretation record — and read them before the architecture.
2. Build the field-level catalogue; find out who signed off the arguable classifications. Usually nobody has.
3. Trace one real disclosure end to end and see whether it can be reconstructed.
4. Ask for last month's expected-versus-actual volumes per feed.
5. Rehearse the assurance pack on test data.
6. Establish the decision list and find out which decisions have actually been taken.
7. Write the capability statement and get the authority to acknowledge it.

Failure pattern	Early signal
Requirements the data cannot satisfy	Continuous location or OTT in the backlog
Scope creep into investigation	Features that 'help the analyst'
Compliance by documentation	A classification spreadsheet no code references
Billing coupling	Retention fed from charging with no gap analysis
Audit as logs	'We have comprehensive logging'
Urgent path as normal path	Rising urgent volumes
Silent feed loss	Nobody can say what yesterday's expected volume was

14. One-liners

- Part 3 acquires, Part 4 retains, Part 9 compels capability — know which one is generating the requirement.
- The entity/events distinction has legal effect, so it must be an enforced attribute of the data model, not a documentation exercise.
- Truncate at ingest, irreversibly: one engineering decision replaces a permanent operational risk.
- Machine determines scope from the authorisation; a human approves release.
- Bindings are intervals, not facts; every lookup is only valid with respect to a time.
- Each identifier hop is a legal act, not a graph traversal.
- Without source port and accurate time, CGNAT resolution is a guess — say 'insufficient information', never guess.
- 'Not our subscriber' and 'no activity' are different facts; collapsing them destroys information.
- Do not enrich third-party identifiers by default — that error is designed in, not operator error.
- Correlate on ICID; never silently join on heuristics.
- Silence looks like a quiet period: reconcile volumes against source-side counts.
- Deletion must produce evidence that outlives the data; crypto-shredding is the answer to backups.
- The same plumbing carries content and communications data; separation is administrative, so its evidence must be exceptional.
- Ambiguity belongs with the authority — which means a clarification message, not an email.
- Misuse looks exactly like use, so detection is not optional.
- Explicability is an architectural veto on opaque matching.
- Over-delivery is a breach too; record the negative decisions.
- Buy the plumbing, own the policy.
- A design authority without a decision list is a reading group.
- Rehearse the assurance pack before go-live; what cannot be produced is a gap in the design.